Note de conseil – Enjeux NIS2 et DORA

Plateforme de paiement « Resilience Alpha » – Workshop 2026, M2, groupe G9

À l'attention de : Direction Nationale de la Sûreté Numérique (commanditaire)
De : Consortium G9, équipe d'ingénierie indépendante
Date : 22 octobre 2026
Objet : conformité NIS2/DORA de la plateforme de paiement, arbitrages retenus et décisions à prendre

1. Synthèse pour la direction

Vous nous avez demandé de vérifier qu'une plateforme de paiement peut détecter un incident et rétablir le service sans intervention humaine. Sur le périmètre que nous avons testé, c'est le cas : lors d'une saturation volontaire du service de connexion, la plateforme a détecté l'anomalie et remis le paiement en état de marche **en 25 secondes au pire**, sans perte de données. Dans le réglage retenu pour la démonstration, la détection prend 11 secondes et la reprise 3 secondes de plus.

Vous nous avez également demandé de renforcer l'accès des opérateurs au back-office. Il exige désormais trois étapes : identifiant, confirmation du visage par une caméra, puis mot de passe. Chaque tentative est journalisée et un objet connecté signale le résultat.

Ces résultats répondent à deux attentes centrales du règlement DORA : se rétablir rapidement après un incident, et protéger les accès par une authentification forte. Ils ne suffisent pas pour autant à rendre l'entreprise conforme. Plusieurs obligations relèvent de l'organisation (gouvernance, notification aux autorités, gestion des prestataires) et ne peuvent pas être démontrées par un prototype de quatre jours.

Nous vous recommandons de valider l'approche de reprise automatique, puis d'engager trois chantiers dans l'ordre suivant : fiabiliser les données (réplication de la base), mettre en place une capacité humaine d'investigation, et industrialiser la plateforme. Le détail figure en partie 6.

2. Ce qui est critique et ce que coûte un arrêt

Nous avons classé les services selon l'effet de leur arrêt sur l'activité. Le paiement est la seule fonction dont l'interruption touche immédiatement les clients et les partenaires ; tout le reste est organisé autour de lui.

Service	Criticité	Effet d'un arrêt	Objectif de reprise
Paiement (API métier et base de données)	Très haute	Aucune transaction possible, partenaires bloqués	Moins de 60 s, automatique
Authentification des clients	Très haute	Plus personne ne peut payer, même si l'API fonctionne	Moins de 60 s, automatique
Supervision et détection	Haute	La plateforme continue, mais on ne voit plus les incidents	5 min, manuel
Back-office des opérateurs	Moyenne	Plus de gestion des habilitations ; les paiements continuent	15 min, manuel
Assistant opérateur (IA)	Faible	Les opérateurs consultent les procédures à la main	Pas d'objectif

Pour donner un ordre de grandeur du coût d'un arrêt, nous avons retenu les hypothèses suivantes, fictives mais plausibles pour un acteur de taille moyenne : 500 paiements par minute en période chargée, un montant moyen de 45 €, et une commission de 0,8 % pour l'entreprise.

Durée de l'arrêt	Paiements non traités	Flux bloqués	Commissions perdues
25 s (reprise automatique, pire cas mesuré)	environ 210	environ 9 400 €	environ 75 €

Durée de l'arrêt	Paiements non traités	Flux bloqués	Commissions perdues
30 min (reprise manuelle, situation de départ)	environ 15 000	environ 675 000 €	environ 5 400 €
4 h (incident mal maîtrisé)	environ 120 000	environ 5,4 M€	environ 43 000 €

La perte directe reste modeste ; le vrai coût est ailleurs. Un arrêt long retarde les opérations des partenaires, entame la confiance des utilisateurs et peut devenir un incident majeur au sens de DORA, qu'il faut alors déclarer aux autorités. Passer de 30 minutes à 25 secondes, c'est d'abord éviter d'en arriver là.

Ces chiffres sont des hypothèses de travail. Ils devront être remplacés par les volumes réels de l'entreprise avant toute décision budgétaire.

3. Quel texte s'applique

NIS2 est la directive européenne générale sur la cybersécurité des secteurs essentiels. DORA est un règlement écrit spécialement pour le secteur financier, centré sur la résilience opérationnelle : résister, se rétablir, le prouver par des tests et prévenir les autorités dans des délais fixés. Pour une entreprise de paiement, DORA s'applique en priorité (il joue le rôle de *lex specialis*). Nous nous appuyons donc surtout sur DORA, en indiquant les références NIS2 équivalentes.

4. Où en est la plateforme face à ces exigences

Le tableau ci-dessous distingue ce que nous avons réellement démontré, avec la preuve correspondante, et ce qui reste à la charge de l'organisation.

Exigence	Référence	Démontré, et preuve	À la charge de l'organisation
Gestion des risques TIC	DORA art. 5-16 · NIS2 art. 21	Analyse EBIOS RM reliée aux mesures en place (conteneurs durcis, réseaux séparés). Preuve : dossier EBIOS, configuration du dépôt	Politique formelle, implication de l'organe de direction, revue annuelle
Contrôle des accès et authentification forte	DORA art. 9.4 · NIS2 art. 21.2 i et j	Back-office en trois étapes (identifiant, visage, mot de passe), blocage 5 min après deux échecs, gestion des habilitations, journal des tentatives. Preuve : parcours de connexion, LED de l'objet connecté	Revue périodique des droits, protection contre l'usurpation (photo), second poste d'authentification
Détection des incidents	DORA art. 10	Détection par apprentissage automatique sur les métriques et journaux. Preuve : détection entre 11 et 18 s, tableau de bord SOC	Surveillance 24 h/24, corrélation de sources multiples
Réponse et rétablissement	DORA art. 11-12	Blocage ou étranglement de la source, redémarrage, transaction de vérification. Preuve : reprise en 25 s au pire, tests de bout en bout	Sauvegardes hors site, site de secours
Notification des incidents	DORA art. 17-19 · NIS2 art. 23	Journal horodaté de chaque incident (début, détection, actions, retour à la normale)	Classification de l'incident, envoi à l'autorité sous 24 h, 72 h et un mois
Tests de résilience	DORA art. 24-26	Scénario d'attaque reproductible lancé depuis un poste distinct, essais de panne (9 reprises sur 9)	Programme de tests annuel, tests TLPT

Exigence	Référence	Démontré, et preuve	À la charge de l'organisation
Risque lié aux prestataires	DORA art. 28-30	Composants, versions et matériel (objet connecté ESP32) inventoriés dans le dépôt	Contrats, registre d'information, stratégie de sortie
Journalisation	NIS2 art. 21.2	Journaux centralisés et exploitables, conservés 72 h, y compris les connexions au back-office	Conservation légale, journaux inaltérables

5. Les arbitrages que nous avons faits

En quatre jours et sur un seul poste de 16 Go, nous avons dû choisir. Chaque choix a un bénéfice et une contrepartie, que nous préférons vous exposer clairement.

Choix	Ce que nous y gagnons	Ce que nous acceptons
Reprise entièrement automatique	Rétablissement en quelques secondes, sans dépendre d'une astreinte	L'automate rétablit la disponibilité ; il n'enquête pas sur une compromission
Docker Compose plutôt que Kubernetes	Imposé par le cahier des charges, tient sur un seul poste, et prouve que c'est bien notre chaîne qui répare	Pas de haute disponibilité native ; un seul poste héberge tout
Une seule base de données	Simplicité, aucune incohérence entre copies	Une perte de la base n'est pas couverte automatiquement
Blocage de la source, ou étranglement si elle est partagée	Coupe l'attaque à la racine ; une adresse partagée par plusieurs clients (passerelle réseau) est limitée à 6 requêtes par minute au lieu d'être coupée, pour ne pas bloquer les clients légitimes	Inefficace contre une attaque répartie sur de nombreuses adresses
Remédiateur aux droits limités (redémarrer, arrêter)	Un remédiateur compromis ne peut pas prendre le contrôle de la plateforme	Il ne peut pas reconstruire un service ; c'est le rôle du playbook de restauration
Reconnaissance faciale légère (OpenCV, sans réseau de neurones)	Fonctionne sur le poste existant, sans carte graphique, entraînement en quelques secondes ; images conservées uniquement sur ce poste	Pas de détection d'usurpation par photo ; sensible à l'éclairage
SOPS plutôt que HashiCorp Vault	Secrets chiffrés dans le dépôt, sans serveur supplémentaire à maintenir	Pas de rotation automatique des secrets

6. Nos recommandations

Chaque recommandation s'appuie sur un constat vérifiable et s'accompagne d'un indicateur qui permettra à la direction de suivre sa mise en œuvre.

Recommandation	Sur quoi elle s'appuie	Indicateur de suivi	Échéance
1. Répliquer la base de données et tester la restauration chaque mois	Notre PCA/PRA montre que la perte de la base n'est pas couverte	Aucune perte de données lors du test mensuel ; restauration en moins de 15 min	0 à 3 mois
2. Mettre en place un SIEM et une astreinte humaine	L'automate rétablit le service mais ne qualifie pas une compromission	Tout incident qualifié en moins de 4 h ; notification initiale prête en moins de 24 h	3 à 6 mois
3. Industrialiser sur un orchestrateur (Kubernetes) avec gestion des droits et règles réseau natives	Un seul poste héberge aujourd'hui toute la plateforme	Disponibilité du paiement de 99,9 % ; reprise automatique maintenue sous 60 s	6 à 12 mois

Ces trois chantiers répondent aux exigences de DORA sur la continuité d'activité (art. 11 et 12), la notification (art. 19) et les tests (art. 24 à 26). Ils corrigent aussi les principaux risques résiduels identifiés dans notre analyse EBIOS. Pour le back-office, nous recommandons en complément une détection d'usurpation (vérification de présence) avant tout usage hors laboratoire.

7. Limites que nous assumons

Notre démonstration couvre une attaque de saturation venant d'une seule source. Restent en dehors du périmètre : une attaque répartie sur plusieurs adresses, la perte de la base de données, un secret partagé entre services, l'absence de chiffrement sur le réseau du laboratoire, la dépendance à un seul poste et l'usurpation de visage par photo. Les mesures citées ont été obtenues le 19 octobre (25 s, pire cas) et le 22 octobre (11 s de détection, 3 s de reprise, réglage de démonstration). Enfin, ces conclusions portent sur un environnement entièrement fictif : elles valident une démarche, pas une mise en production.